Remediation Plan

TRACEGUARD | Evidence snapshot

Schema Version
1.0

Bundle Id
141d20fe-a641-404b-86cf-11124e6be45c

Generated At
2026-10-31T23:05:47.403Z

Advisory Snapshot Id
4c39ba350422d87221eeb59b11d3cafd88595791f9c97a8e3d32a2eb28448984

Inventory Counts

Project Modules
1

Unique Packages
1

Unique Package Versions
1

Dependency Instances
1

Direct Dependencies
1

Transitive Only Dependencies
0

Unknown Relationships
0

Dependency Edges
1

Unresolved Declarations
0

Scan Evidence

Scanner Version
0.2.0

Archive Sha256
8e590fb7559d410dad475198b93df9c1ac9c216073581ceb978c3b19b2322a60

Revision Status
unknown

Inventory Sha256
cc42bf40510dcd5a85d401114cb26b84e2dc5ac2ac2a011da4cb415d321680fd

Languages

1.
JavaScript

Projects

1.

Path
.

Manager
npm

Status
analyzed

Reasons
(none recorded)

2.

Path
.

Manager
npm

Status
analyzed

Reasons
(none recorded)

Metadata Hashes

1.

Path
package-lock.json

Sha256
2ba44094cdd18baf4af77414649dcee2b094a1ec27786be907759740db06a319

2.

Path
package.json

Sha256
1fb0138b887620f5958630e97b8dc82fbc8ab22719411050e291903d1fd32fc8

Scan

Id
79573486-0a6c-48e6-8f41-1295a790db58

Source
ZIP upload

Created At
2026-10-31T23:05:44.548Z

Inventory Sha256
cc42bf40510dcd5a85d401114cb26b84e2dc5ac2ac2a011da4cb415d321680fd

Coverage

Status
complete

Checked At
2026-10-31T23:05:44.550Z

Package Instances
1

Matched
1

No Known Match
0

Unknown
0

Findings Included
1

Findings Omitted
0

Limitations

1.
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

2.
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

3.
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

4.
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

5.
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per finding are included. Descriptions, references, paths and source evidence are bounded.

6.
Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

7.
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

8.
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

9.
Transitive updates require changes to the owning dependency declaration or parent. No dependency graph or lockfile is changed automatically.

10.
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

11.
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

Report Type
remediation-plan

Title
Remediation Plan

Actions

1.

Finding Id
F-001

Package Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Package Name
lodash

Installed Version
4.17.20

Status
MANUAL REVIEW

Verification

Checked At
2026-10-31T23:05:49.305Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-29mw-wpgm-hmr9

2.
https://api.osv.dev/v1/vulns/GHSA-35jh-r3h4-6jhm

3.
https://api.osv.dev/v1/vulns/GHSA-f23m-r3pf-42rh

4.
https://api.osv.dev/v1/vulns/GHSA-r5fr-rjxr-66jc

5.
https://api.osv.dev/v1/vulns/GHSA-xxjr-mmjv-4gpg

Candidate Advisory Status
not-verified

Compatibility
NOT TESTED

Steps

1.
No publishable, advisory-clean upgrade candidate could be verified within the report coverage. Do not assume that latest, a fixed boundary, or an unavailable query is safe.

2.
Review the cited advisories for lodash@4.17.20, published maintainer fixes, and all owning parent paths. Verify a compatible release before choosing an upgrade.

3.
If no supported fix exists, evaluate removing or replacing the dependency, disabling the affected feature, or applying a maintainer-reviewed patch. These are manual options, not verified mitigations.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-29mw-wpgm-hmr9

2.
https://nvd.nist.gov/vuln/detail/CVE-2020-28500

3.
https://github.com/github/advisory-database/pull/6139

4.
https://github.com/lodash/lodash/pull/5065

5.
https://github.com/lodash/lodash/pull/5065/commits/02906b8191d3c1 00c193fe6f7b27d1c40f200bb7

6.
https://github.com/lodash/lodash/commit/c4847ebe7d14540bb28a8b932 a9ce1b9ecbfee1a

7.
https://www.oracle.com/security-alerts/cpuoct2021.html

8.
https://www.oracle.com/security-alerts/cpujul2022.html

9.
https://www.oracle.com/security-alerts/cpujan2022.html

10.
https://www.oracle.com//security-alerts/cpujul2021.html

11.
https://snyk.io/vuln/SNYK-JS-LODASH-1018905

12.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074893

13.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074895

14.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074892

15.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074894

16.
https://osv.dev/vulnerability/GHSA-35jh-r3h4-6jhm

17.
https://nvd.nist.gov/vuln/detail/CVE-2021-23337

18.
https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b 5a91dde28ba4b1c

19.
https://snyk.io/vuln/SNYK-JS-LODASH-1040724

20.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929

21.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074931

22.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928

23.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930

24.
https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932

25.
https://security.netapp.com/advisory/ntap-20210312-0006

26.
https://github.com/rubysec/ruby-advisory-db/blob/master/gems/loda sh-rails/CVE-2021-23337.yml

27.
https://osv.dev/vulnerability/GHSA-f23m-r3pf-42rh

28.
https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh

29.
https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg

30.
https://nvd.nist.gov/vuln/detail/CVE-2026-2950

31.
https://github.com/lodash/lodash

32.
https://osv.dev/vulnerability/GHSA-r5fr-rjxr-66jc

33.
https://github.com/lodash/lodash/security/advisories/GHSA-r5fr-rjxr-66jc

34.
https://nvd.nist.gov/vuln/detail/CVE-2026-4800

35.
https://cna.openjsf.org/security-advisories.html

36.
https://github.com/advisories/GHSA-35jh-r3h4-6jhm

37.
https://osv.dev/vulnerability/GHSA-xxjr-mmjv-4gpg

38.
https://nvd.nist.gov/vuln/detail/CVE-2025-13465

39.
https://github.com/lodash/lodash/commit/edadd452146f7e4bad4ea684e 955708931d84d81

40.
https://cert-portal.siemens.com/productcert/html/ssa-253495.html

41.
https://docs.npmjs.com/cli/v11/commands/npm-install/

42.
https://docs.npmjs.com/cli/v11/configuring-npm/package-json/#overrides

43.
https://docs.npmjs.com/cli/v11/commands/npm-explain/

Package Risk

Checked At
2026-10-31T23:05:49.305Z

Coverage

Total
1

Metadata Checked
1

Unavailable
0

Skipped
0

Results

1.

Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Registry
sha512-PlhdFcillOINfeV7Ni6oF1TAEayyZBoZ8bcshTHqOYJYlrqzRK5hagpagk y5o4HfCzzd1TRkXPMFq6cKk9rGmA==

Shasum
b44a9b6297bcb698f1c51a3545a2b3b368d59c52

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEUCIQDPF8qtGU3yxHj4Yw4h9hpt+DCVT9dlk9ApvKxVXPwv7AIgSLC2TkL6ONbFl hyV2ZcE4v52ANJMoA/ HwKY+zKt9Kh4=

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/lodash/4.17.20

Metadata

Description
Lodash modular utilities.

License
MIT

Repository
https://github.com/lodash/lodash.git

Homepage
https://lodash.com/

Maintainers

1.
bnjmnt4n

2.
jdalton

3.
mathias

Lifecycle Scripts

Limitations

1.
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

2.
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

3.
At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

4.
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

5.
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

6.
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

Sources

1.
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

2.
https://docs.npmjs.com/viewing-package-provenance/

3.
https://docs.npmjs.com/cli/v11/commands/npm-audit/

4.
https://osv.dev/

Coverage Actions

1.
Validate changes in a trusted development environment. TRACEGUARD does not execute fixes or submitted source code.